Vulnerabilities Are Cattle, Not Pets

25 Feb 2025 · 7 min read Tweet

For years, organizations have relied on CVSS to assess and prioritize vulnerabilities. The framework was built by incredibly smart people, and developing it wasn't easy. The problem isn't CVSS itself but rather what it aims to achieve and, more importantly, how people use it.

The Problem With CVSS

First, many very smart people have worked on CVSS for a long time, and I'm sure putting it together wasn't easy. They definitely did a great job. The issue lies more in what they were trying to achieve and how people use their work.

To give you an idea of where I'm coming from:

- I've seen organizations spend more time manually selecting which patches to apply based on CVSS scores than simply deciding, "Let's apply them all," regardless of how difficult the patch is to implement.
- Then, the pentest or vulnerability assessment team goes through each finding, deciding whether to report a bug based on whether it appears on their list of things to fix. Again, this isn't a problem with CVSS itself—it's a problem with how people use scoring.
- We spend too much time rating vulnerabilities and not enough time fixing them. Who hasn't been in a meeting where a few risk managers—probably earning a few hundred thousand a year—argue over whether a vulnerability is an 8 or a 9, only to dump it into a risk register, never to be

> looked at again? On top of that, we waste too much time re-rating vulnerabilities to assess their risk in our specific environment. Maybe those risk managers' salaries would be better spent on people actually deploying patches and fixing vulnerabilities.

One fundamental issue with CVSS is that it tries to be everything for everyone. We can't score all bug classes or systems on the same scale and expect meaningful results. Ideally, we should have separate scoring models: **CVSS for hardware, CVSS for operating systems, and CVSS for web applications**, each tailored to their unique risk profiles and variables.

A one-size-fits-all approach introduces too many layers of abstraction, stripping away the information that truly matters. If we categorized vulnerabilities by system type (web, hardware, OS, etc.), risk calculations would be far more relevant in their specific contexts.

The Score Obsession Problem

The reliance on numerical scores often leads to an ineffective approach to remediation. A common mindset is: "Let's fix all vulnerabilities rated 8 and above this quarter, then we'll see." Who hasn't heard this before?

This method actually makes remediation harder. It's like asking developers or ops teams to walk through a field of plants and only pick the ones taller than 10 centimeters. They end up running all over the place instead of systematically addressing issues. A more efficient approach would be to clear the first half of the field instead.

Oversimplification of Risk

Another major flaw in CVSS-based decision-making is the oversimplification of risk. A vulnerability's impact cannot be boiled down to a single number. Real-world vulnerabilities are complex, context-dependent, and interconnected. But numbers are easy to drop into an Excel file, so they persist.

Ironically, CVSS fails to properly capture (by design) one of the most crucial aspects of vulnerability management: **the complexity and effort required for remediation**. Organizations often spend weeks debating whether a vulnerability is a CVSS 8 or 9, rather than assessing the actual difficulty of implementing a fix and whether the issue is actively being exploited.

The Cattle vs. Pets Mindset Shift

We need to stop treating vulnerabilities as unique and special cases, deciding each one's fate based on an arbitrary score. DevOps revolutionized

infrastructure by shifting from a mindset of **pets (carefully managed, individual machines)** to **cattle (interchangeable, disposable systems)**. Vulnerability management needs the same transformation.

Vulnerabilities aren't pets that need to be named, assessed, and debated one by one. They're **cattle**—handled in bulk, remediated continuously, and managed efficiently.

Chained Vulnerabilities and Systemic Risk

Another flaw in traditional vulnerability management is that it treats every vulnerability as an isolated issue. But in the real world, attackers **chain vulnerabilities** together to escalate impact. A low-scoring vulnerability in one system could become critical when combined with another issue. By focusing too much on individual CVSS scores, organizations fail to see the bigger picture.

Additionally, security teams should prioritize **removing entire classes of vulnerabilities** rather than playing an endless game of patching individual flaws. Fixing the root cause—whether it's insecure defaults, lack of sandboxing, or weak authentication—eliminates entire categories of risk rather than constantly reacting to new CVEs.

Time for a Mindset Shift

We've reached a point where vulnerabilities are so numerous that the only viable approach is **continuous patching**, not selective patching based on scores. The security industry needs to stop treating vulnerabilities as one-off problems to be ranked and debated. Instead, we need scalable, systemic solutions that reduce attack surfaces as a whole.

Vulnerabilities aren't pets. They're cattle. Treat them that way, and remediation will finally become manageable.

Want to build these skills hands-on?

PentesterLab has 700+ real-world labs on web hacking, code review, and vulnerability analysis. Start with a free account.

Create Free Account

Go PRO



Louis Nyffenegger
FOUNDER AND CEO @PENTESTERLAB

RELATED POSTS

- Building Blocks
- How Homogenization of the Development Process Scales Application Security
- Do You Care About Exploitability?